CONTOH · DOMAIN FIKTIF, STRUKTUR LAPORAN SEBENARNYA

Yang Anda dapat dari satu kredit

Setiap temuan di bawah berasal dari pemeriksaan yang benar-benar dijalankan pemindai. Domain dan buktinya fiktif. Laporan Anda berupa PDF berbahasa Inggris dengan struktur ini, dapat diunduh dari dasbor; PDF lengkapnya juga memuat metodologi dan lampiran bukti.

---

1 · Kontrol dokumen

Target `shop.example.com`

Jenis asesmen
Eksternal · tanpa autentikasi · read-only

Kepemilikan
Diverifikasi lewat TXT _netsekurity

Selesai 2026-09-01 09:14 UTC

Disusun oleh
Netsekurity.com Security Agent

Klasifikasi
Rahasia: hanya pemilik dan operator

2 · Ringkasan temuan

1 High | 2 Medium | 2 Low | 4 Info

Postur keseluruhan: perlu perhatian. Satu file yang terbuka bisa membocorkan kredensial hari ini; sisanya adalah penguatan.

3 · Register risiko

#	Temuan	Tingkat keparahan
F-01	File environment terbuka di /.env CVSS 7.5 · CWE-538 · OWASP A05 · A02	High
F-02	Header keamanan hilang (4 dari 6) CVSS 5.3 · CWE-1021 · OWASP A05	Medium
F-03	Open redirect melalui ?next= CVSS 5.4 · CWE-601 · OWASP A01	Medium
F-04	Versi server terungkap (nginx/1.18.0) CVSS 3.7 · CWE-200 · OWASP A05	Low
F-05	Sertifikat TLS kedaluwarsa dalam 41 hari CVSS 3.7 · CWE-295 · OWASP A02	Low
I-01…04	Resolusi DNS · 7 subdomain · WAF terdeteksi · entri disallow di robots.txt	Info

4 · Temuan dan analisis

F-01 · File environment terbuka di /.env High · CVSS 7.5

Yang kami lihat: Path /.env menjawab HTTP 200 dengan isi 1,2 KB. File dengan nama ini biasanya berisi kata sandi database, kunci API, dan rahasia penandatanganan. Kami tidak menyimpan isinya.

Bukti: `GET /.env -> 200 1247`

Dampak: Siapa pun bisa membaca rahasia produksi Anda.

Perbaikan: Blokir file itu di web server (nginx: `location ~ /\.env { deny all; }`), pindahkan ke luar web root, lalu ganti setiap rahasia di dalamnya: anggap sudah terbaca.

F-02 · Header keamanan hilang Medium · CVSS 5.3

Yang kami lihat: Respons tidak memiliki strict-transport-security, content-security-policy, referrer-policy, dan permissions-policy. x-frame-options dan x-content-type-options ada.

Bukti: `missing=strict-transport-security, content-security-policy, referrer-policy, permissions-policy`

Perbaikan: Tambahkan keempat header di proxy atau framework. Mulai HSTS dengan max-age=300, naikkan menjadi setahun setelah tidak ada yang rusak. CSP `default-src 'self'` ditambah host CDN Anda adalah versi pertama yang aman.

F-03 · Open redirect melalui ?next= Medium · CVSS 5.4

Yang kami lihat: Permintaan /?next=https://evil.example dijawab dengan 302 ke alamat eksternal itu.

Bukti: `GET /?next=https://evil.example -> 302 https://evil.example`

Dampak: Tautan phishing bisa membawa domain asli Anda dan tetap mendarat di halaman penyerang.

Perbaikan: Hanya terima path relatif yang diawali satu /, atau periksa tujuannya terhadap daftar izin host milik Anda sendiri.

F-04, F-05, dan empat butir informasional

F-04 · Versi server terungkap. `server: nginx/1.18.0` memberi tahu penyerang CVE mana yang harus dicoba. Setel `server_tokens off;`.

F-05 · Sertifikat kedaluwarsa dalam 41 hari. Penerbit Let's Encrypt, 3 entri SAN. Pastikan perpanjangan otomatis berjalan; sertifikat yang kedaluwarsa membuat situs tidak bisa diakses.

I-01 · DNS. Apex mengarah ke 203.0.113.10. **I-02 · Subdomain.** 7 host ditemukan lewat certificate transparency, termasuk staging.shop.example.com: pastikan memang dimaksudkan publik. **I-03 · WAF.** Sidik jari Cloudflare ada. **I-04 · robots.txt.** Melarang /admin/, yang menegaskan bahwa path itu ada.

5 · Rencana perbaikan (30 / 60 / 90)

HARI INI

Blokir /.env. Ganti setiap rahasia di dalamnya.

BULAN INI

Perbaiki redirect. Tambahkan HSTS, CSP, Referrer-Policy, dan Permissions-Policy.

KUARTAL DEPAN

Sembunyikan versi server. Putuskan apakah staging. memang harus publik. Pindai ulang (1 kredit) untuk memastikan.

6 · Yang tidak dicakup laporan ini

Tidak ada yang berada di balik login, tidak ada pengujian otorisasi (IDOR) atau logika bisnis, dan tidak ada payload injeksi (SQLi, XSS, LFI). Itu memerlukan tingkat whitebox. Temuan yang tidak muncul berarti “tidak dipindai”, bukan “terbukti aman”. Daftar lengkapnya ada di halaman **cakupan produk**.